

Od wietnamskiego hakera na stronie pasieki do honeypotów

Analiza zaawansowanych metod wykrywania cyberzagrożeń

0 mnie



Security Architect



Consultant



Microsoft Certified Trainer



AI & Cybersecurity Practitioner



Developer



Freelancer



Azure @ ❤️



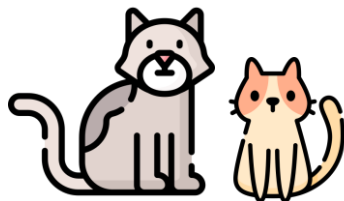
Google Cloud



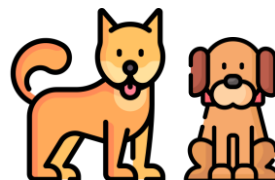
1 Mąż



1 Córka



2 Koty



2 Psy



Kryminały

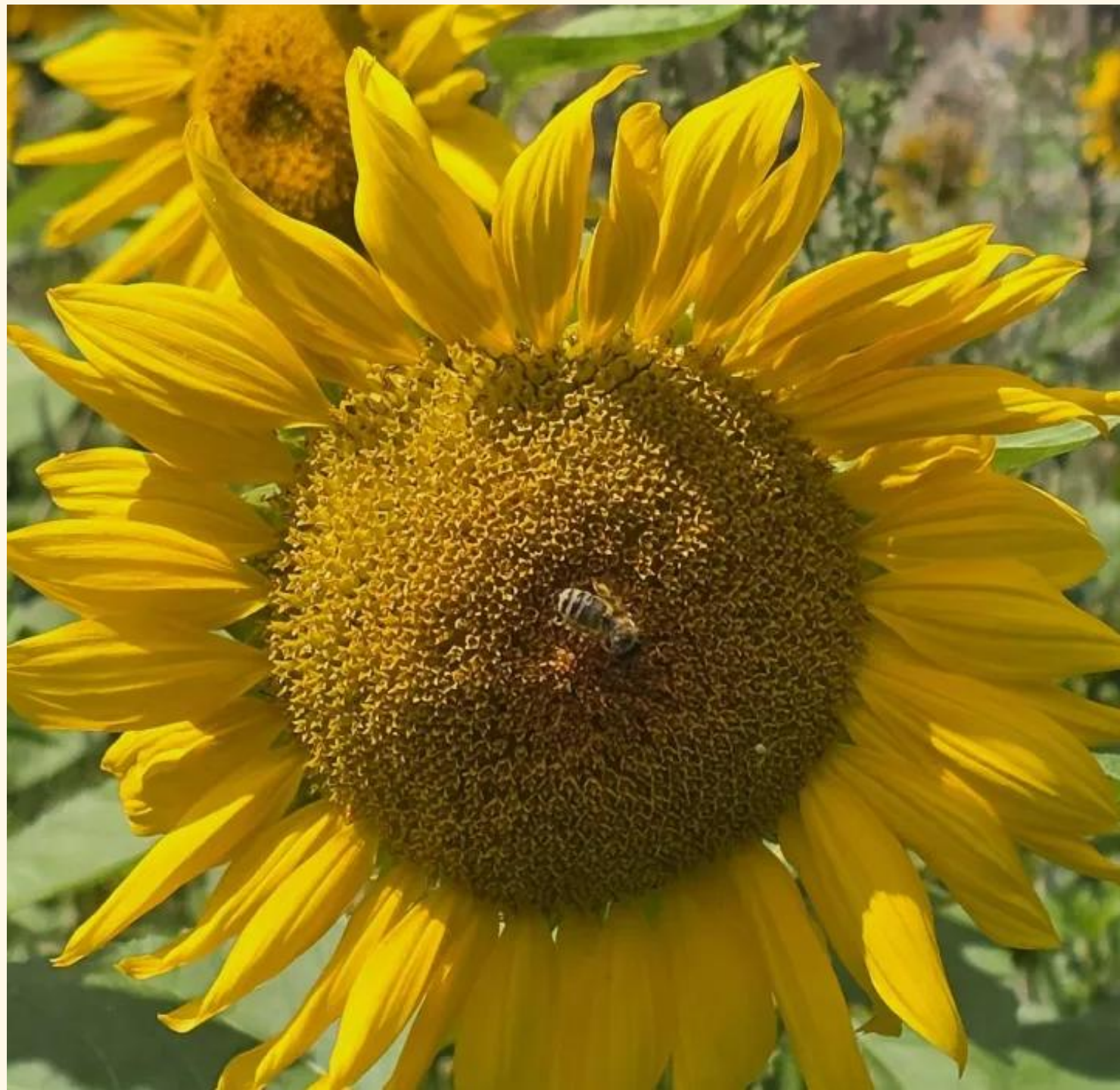


Fotografia

Historia jednej pasieki

Wszystko zaczęło się od rodzinnej pasieki i małej strony na WordPressie. Nie była to korporacja, a cel ataku wydawał się absurdalny.

Jednak, gdy "wietnamski haker" przejął kontrolę, narodziło się pytanie: dlaczego? To doświadczenie stało się fundamentem pracy badawczej nad honeypotami.



Garnuszek z miodem (Honeypot)



Więcej niż bajka o Puchatku

W cyberbezpieczeństwie "garnuszek z miodem" to wyrafinowana pułapka. To system, który wygląda na łatwy cel, ale w rzeczywistości jest skrupulatnie monitorowanym środowiskiem.

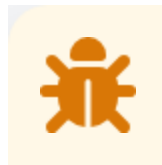
Jego jedynym celem jest zostanie zaatakowanym, abyśmy mogli zrozumieć, kto nas atakuje i jak to robi.

Cyfrowa Pasieka: Metafory



Pasieka

Nasza infrastruktura sieciowa. Zbiór systemów, które chcemy chronić przed intruzami.



Rój (Pszczoły)

Cyberprzestępcy i boty. Często działają w grupach, szukając luk i "słodkich" zasobów.



Ule (Honeypoty)

Specjalnie przygotowane, sztuczne środowiska, które wabią rój, odciągając go od prawdziwych zasobów.

Poziomy Interakcji: Wybór Przynęty

Niska Interakcja

Symulują tylko podstawowe usługi (np. port 80). Są bezpieczne i łatwe w utrzymaniu, ale gromadzą ograniczone dane.

Przykład: Prosty skrypt udający formularz logowania.

Wysoka Interakcja

Pełnoprawne systemy operacyjne z prawdziwymi aplikacjami. Ryzykowne, ale pozwalają hakerowi na pełne "rozwiniecie skrzydeł".

Cel: Obserwacja pełnego procesu ataku i zachowania intruza.

Pułapka na WordPressa

Skonfigurowaliśmy honeypot udający słabo zabezpieczoną stronę pasieki. Wyglądała jak standardowy WordPress, zachęcając do ataku.

- ✓ **Realizm:** Prawdziwe wtyczki i motywy.
- ✓ **Monitoring:** Każde kliknięcie, wpisane hasło i przesłany plik były logowane.
- ✓ **Izolacja:** System odseparowany od prawdziwej sieci domowej.



DEEP DIVE: Zaglądając do ula

Czas zobaczyć, jak wygląda log z ataku. Jakie narzędzia symulują popularne usługi (SSH, HTTP)?

Przygotujmy się na demonstrację!



Zbieranie wywiadu (TTPs)

Czego uczymy się obserwując intruza?

- ⚙️ **Taktyki:** Jakie są cele napastnika? (np. kradzież danych, instalacja koparki krypto).
- </> **Techniki:** Jakich narzędzi używają? (np. SQL Injection, Brute Force).
- ⌘ **Procedury:** W jakiej kolejności wykonują działania? To pozwala nam tworzyć "podpis" grupy przestępczej.
- 🛡️ **Wniosek:** Poznajemy wroga, zanim zaatakuje nasze prawdziwe systemy.

Cykl życia pułapki



1. Wdrożenie

Instalacja honeypota i konfiguracja usług (np. fałszywy panel admina).



2. Wabienie

Wystawienie systemu do sieci publicznej. Czekanie na "szum" skanerów.



3. Interakcja

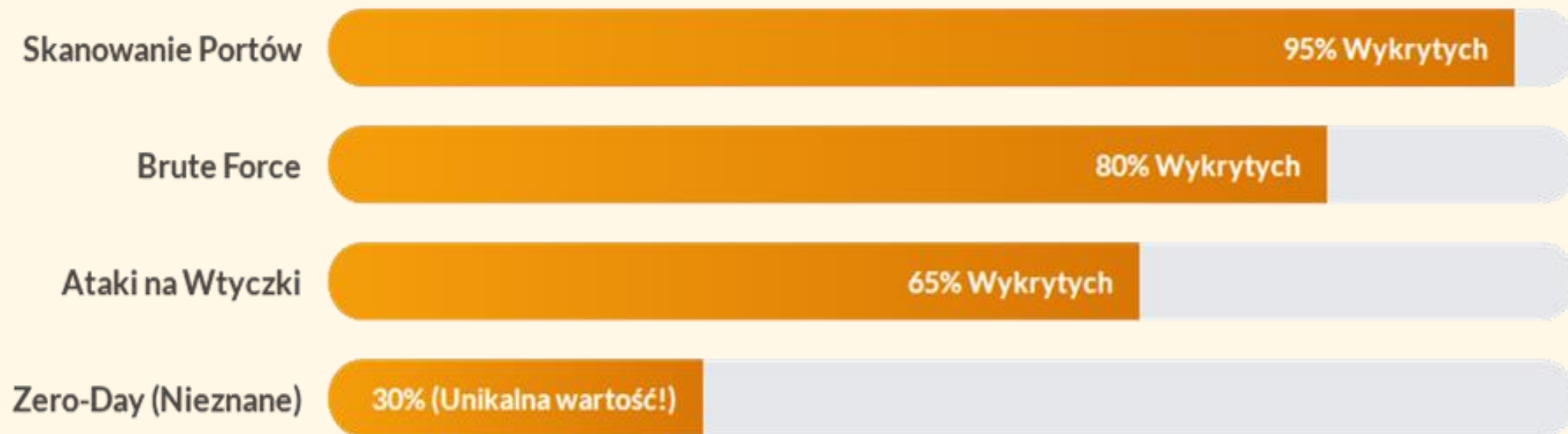
Atakujący wchodzi do systemu. Rejestracja wszystkich komend i plików.



4. Analiza

Przetwarzanie logów, identyfikacja TTPs i aktualizacja ochrony.

Wartość danych: unikalne wnioski



Honeypoty pozwalają wykryć nawet te ataki, których sygnatury nie są jeszcze znane antywirusom.

Wyzwania w pasiece



Utrzymanie

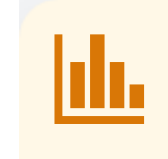
Honeypoty wysokiej interakcji są skomplikowane.

Wymagają ciągłych aktualizacji, aby wyglądały wiarygodnie.



Ryzyko

Jeśli haker zorientuje się, że jest w pułapce, może próbować użyć jej jako trampoliny do ataku na resztę sieci.



Analiza danych

Oddzielenie szumu (botów) od wartościowych danych o zaawansowanych atakach wymaga czasu i wiedzy.

Od Reakcji do Proakcji

Zamiast czekać na włamanie, przejmujemy inicjatywę. Honeypoty zmieniają zasady gry, pozwalając nam uczyć się na błędach napastników, a nie własnych.



Pytania?

Dziękuję za uwagę.

Zapraszam do dyskusji o garnuszkach z miodem i
bezpieczeństwie.

Stale poszukuję nowych możliwości i ekscytujących wyzwań. Jeśli chcesz się ze mną skontaktować, proszę, skorzystaj z poniższych kanałów:

Email: info@zalnet.pl

LinkedIn: <https://www.linkedin.com/in/beatazalewa/>

Blog: <https://zalnet.pl/blog/>

X: <https://x.com/beatazalewa>

GitHub: <https://github.com/beatazalewa/Conferences/>

